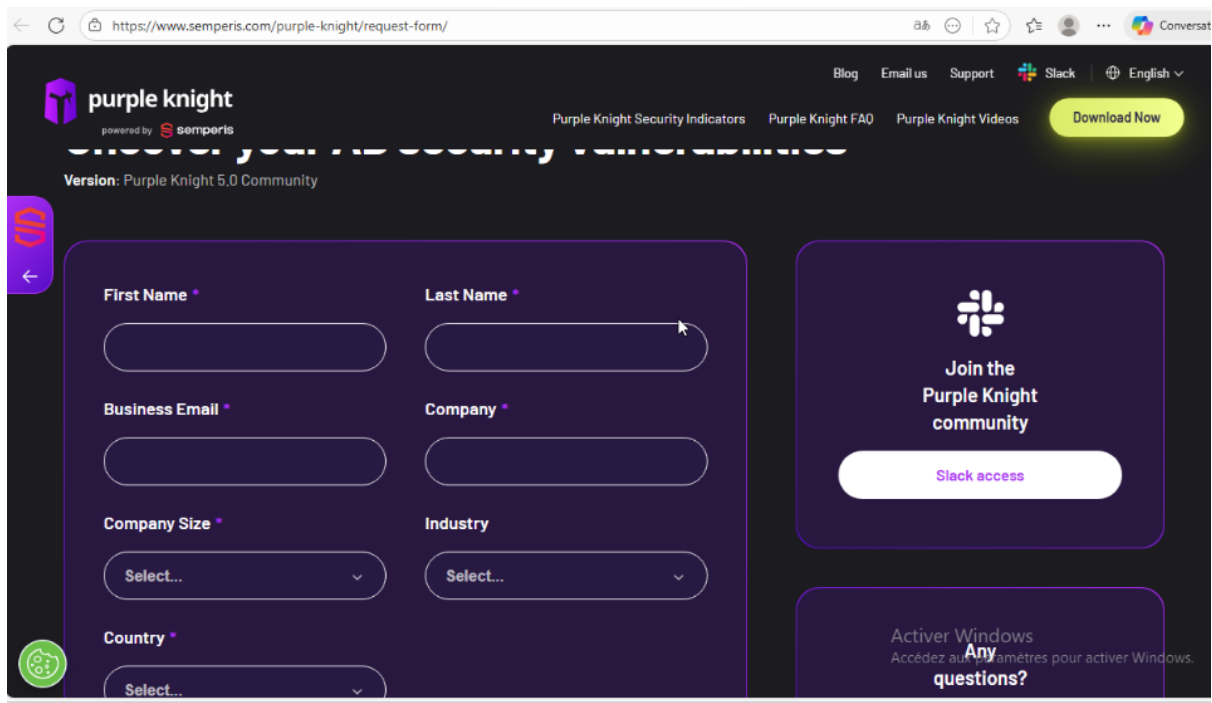


# Audit de Sécurité Active Directory avec Purple Knight

## 1. Introduction à l'outil

**Purple Knight** est un outil d'audit de sécurité développé par Semperis. Contrairement à un simple scanner de vulnérabilités, il se concentre sur les **Indicateurs d'Exposition (IoE)** et les **Indicateurs de Compromission (IoC)** spécifiques à l'Active Directory.

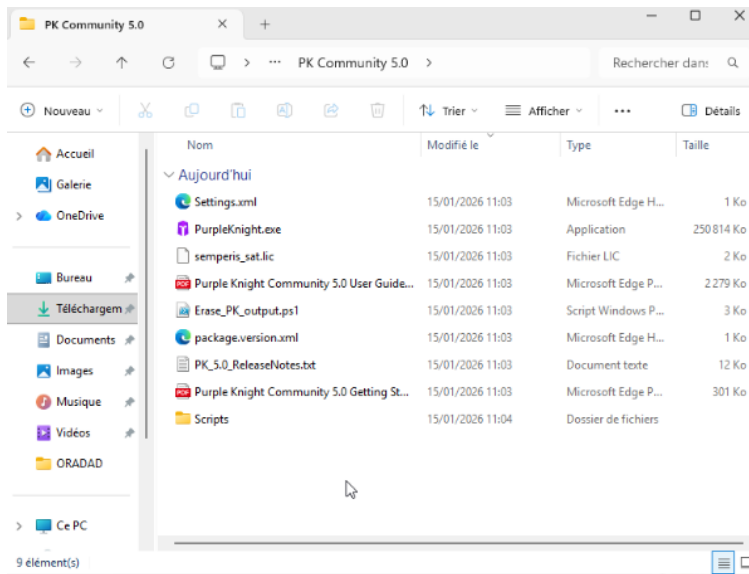


The screenshot shows the 'request-form' page of the Purple Knight tool. The page has a dark theme with purple accents. At the top, there's a navigation bar with links for 'Blog', 'Email us', 'Support', 'Slack', and 'English'. A 'Download Now' button is highlighted in yellow. The main content area features a form with fields for 'First Name', 'Last Name', 'Business Email', 'Company', 'Company Size', 'Industry', and 'Country'. To the right of the form, there's a section titled 'Join the Purple Knight community' with a 'Slack access' button. At the bottom right, there's a small 'Active Windows' notification.

## 2. Phase de Lancement et Configuration

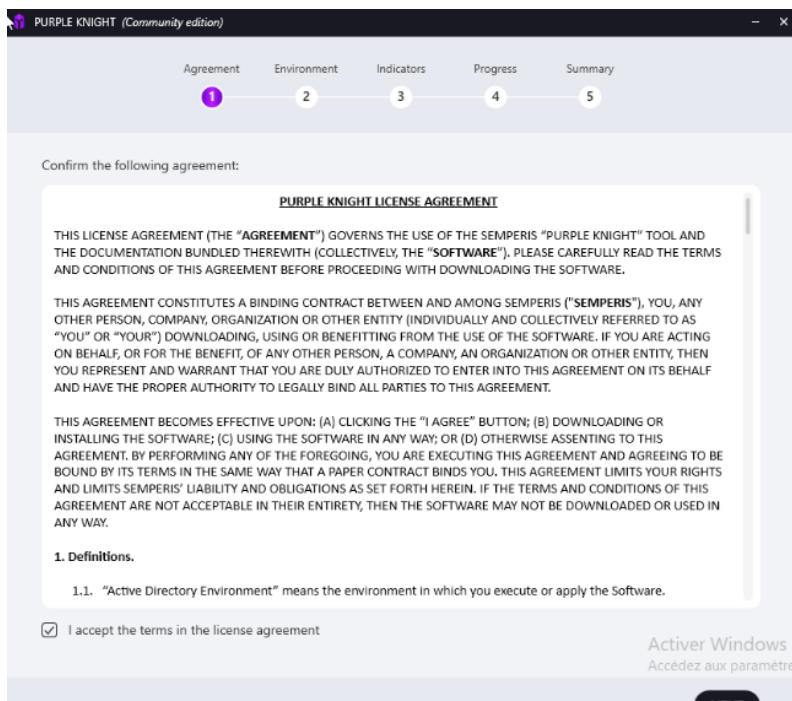
### A. Exécution du programme

- **Action** : Lancement de PurpleKnight.exe.
- **Commentaire** : L'outil s'exécute sans installation. Il nécessite d'être lancé depuis une machine membre du domaine avec un compte disposant de droits de lecture sur l'ensemble de l'annuaire (généralement un administrateur du domaine pour un scan complet).



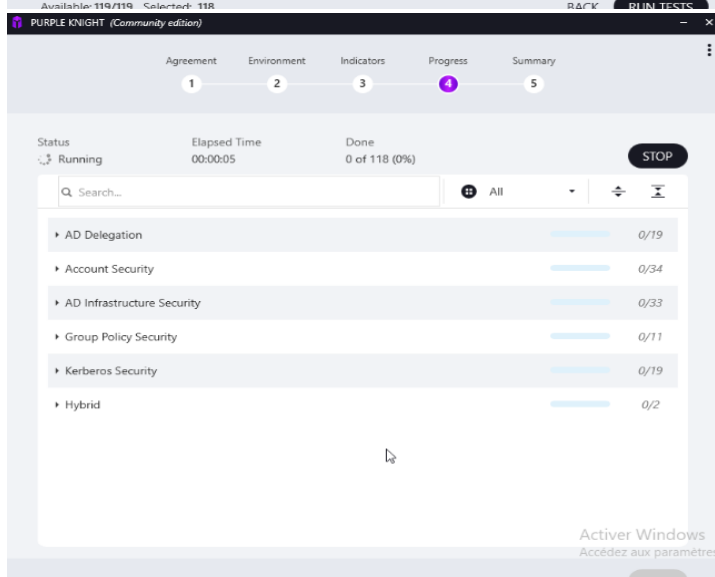
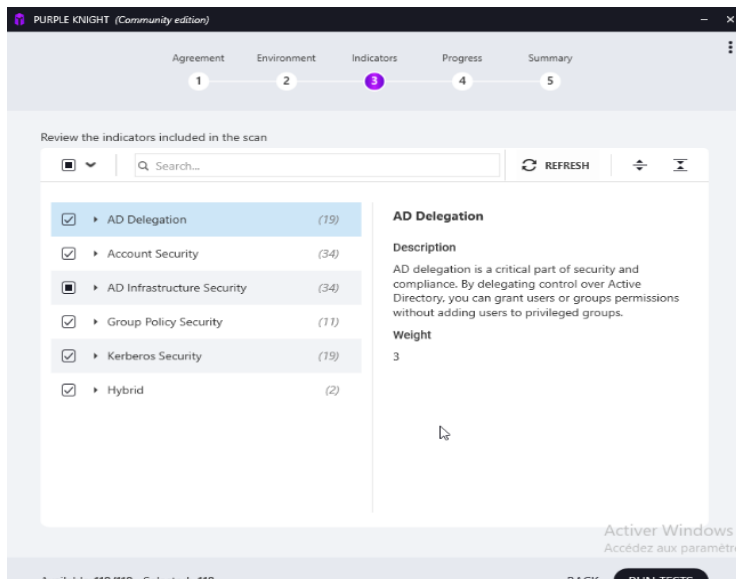
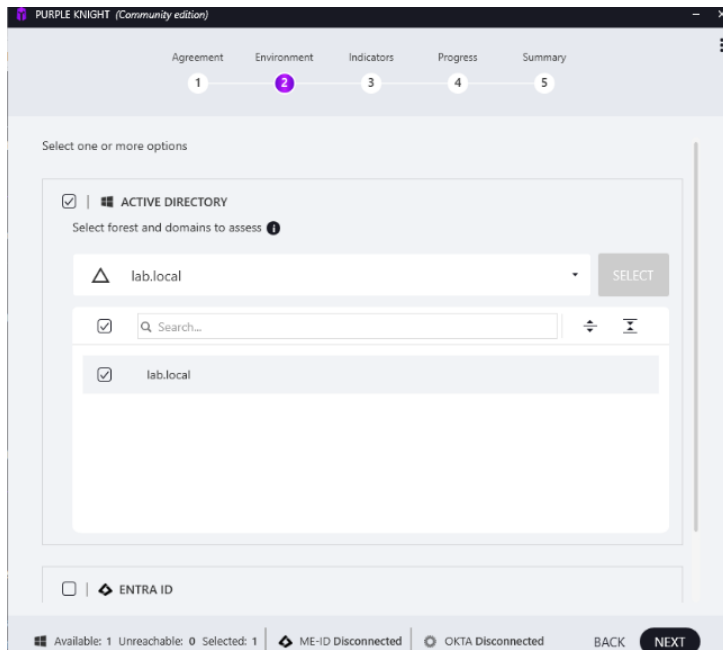
## B. Acceptation des termes et conditions

- **Action** : Validation de la licence "Community Edition".
- **Commentaire** : Cette version est gratuite pour les audits ponctuels et permet d'accéder à plus de 100 indicateurs de sécurité mis à jour régulièrement.



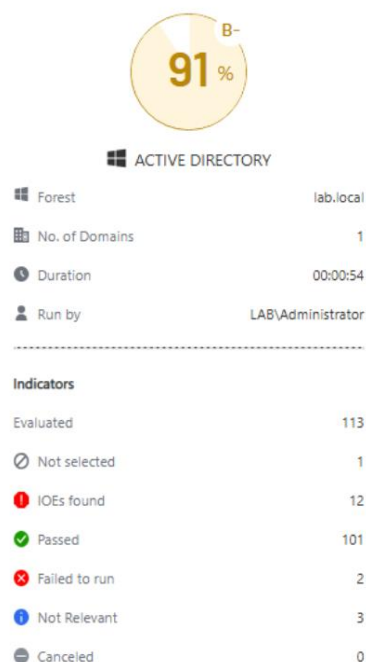
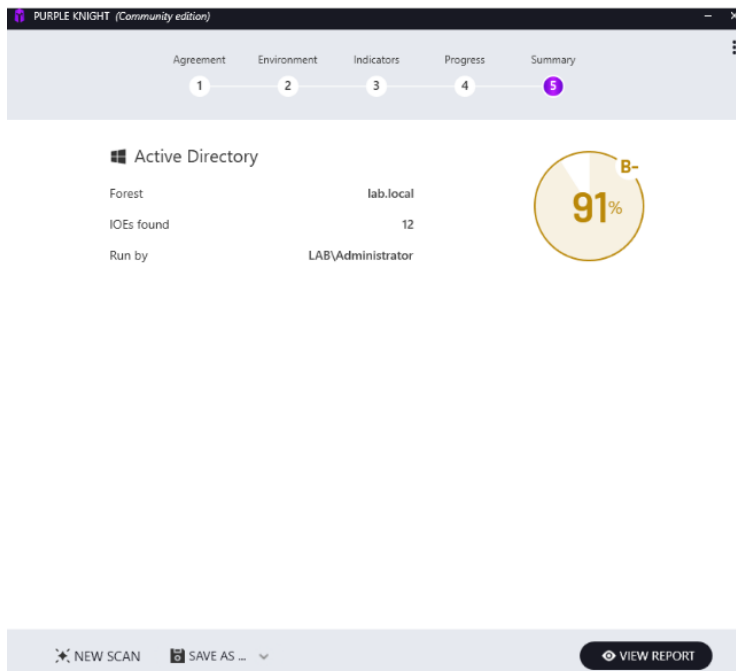
## C. Sélection du périmètre

- **Action** : Choix du domaine lab.local.
- **Commentaire** : L'outil détecte automatiquement la forêt et le domaine actuels. On sélectionne ici l'Active Directory comme cible principale.



### 3. Analyse du Score Global

- **Score obtenu : 91% (Grade B-).**
- **Explication :** Ce score est une moyenne pondérée. Bien que le chiffre semble élevé, la présence de vulnérabilités dans la catégorie "Critical" (Sévérité Critique) signifie que le domaine peut être compromis malgré une bonne note globale.



## 1 CRITICAL IOEs FOUND

### ■ SMB Signing is not required on Domain Controllers

This indicator looks for domain controllers where SMB signing is not required.

[Read More](#)

### ■ SMBv1 is enabled on Domain Controllers

This indicator looks for domain controllers where SMBv1 protocol is enabled.

[Read More](#)

## ADDITIONAL IOEs FOUND

| NAME                                                                   | PLATFORM | SEVERITY LEVEL                                                            | ACTION                    |
|------------------------------------------------------------------------|----------|---------------------------------------------------------------------------|---------------------------|
| • LDAP signing is not required on Domain Controllers                   | ■ AD     | High <div><div></div><div></div><div></div><div></div><div></div></div>   | <a href="#">Read More</a> |
| • Write access to RBCD on DC                                           | ■ AD     | High <div><div></div><div></div><div></div><div></div><div></div></div>   | <a href="#">Read More</a> |
| • Write access to RBCD on krbtgt account                               | ■ AD     | High <div><div></div><div></div><div></div><div></div><div></div></div>   | <a href="#">Read More</a> |
| • Built-in domain Administrator account used within the last two weeks | ■ AD     | Medium <div><div></div><div></div><div></div><div></div><div></div></div> | <a href="#">Read More</a> |
| • gMSA not in use                                                      | ■ AD     | Medium <div><div></div><div></div><div></div><div></div><div></div></div> | <a href="#">Read More</a> |
| • Domains with obsolete functional levels                              | ■ AD     | Low <div><div></div><div></div><div></div><div></div><div></div></div>    | <a href="#">Read More</a> |
| • Recent privileged account creation activity                          | ■ AD     | Low <div><div></div><div></div><div></div><div></div><div></div></div>    | <a href="#">Read More</a> |
| • Unprivileged users can add computer accounts to the domain           | ■ AD     | Low <div><div></div><div></div><div></div><div></div><div></div></div>    | <a href="#">Read More</a> |
| • AD objects created within the last 10 days                           | ■ AD     | Info <div><div></div><div></div><div></div><div></div><div></div></div>   | <a href="#">Read More</a> |
| • Protected Users group not in use                                     | ■ AD     | Info <div><div></div><div></div><div></div><div></div><div></div></div>   | <a href="#">Read More</a> |

## Analyse des Indicateurs d'Exposition (IoE)

### Risques de Sévérité Haute (Critiques)

- **Signature LDAP non requise sur les DC (+ High)** : Le serveur n'exige pas que les échanges LDAP soient signés. Un attaquant peut intercepter ces communications (Man-in-the-Middle) pour voler des identifiants ou injecter des modifications dans l'annuaire sans être détecté.
- **Accès en écriture à la RBCD sur le DC et le compte krbtgt (+ High)** : Il existe des permissions d'écriture sur la délégation Kerberos basée sur les ressources (RBCD) pour des objets critiques. Cela permet potentiellement à un attaquant de prendre le contrôle total du contrôleur de domaine ou de compromettre le compte krbtgt (clé de voûte de la sécurité Kerberos).

### Risques de Sévérité Moyenne

- **Utilisation du compte Administrateur intégré (+ Medium)** : Le compte "Administrateur" par défaut a été utilisé au cours des deux dernières semaines. La bonne pratique veut que ce compte soit désactivé ou réservé aux urgences absolues, au profit de comptes administratifs nominatifs.
- **gMSA non utilisé (+ Medium)** : Vous n'utilisez pas de comptes de service gérés par le groupe (group Managed Service Accounts). Sans gMSA, les mots de passe des services sont souvent statiques et plus faciles à compromettre.

## Risques de Sévérité Faible & Infos

- **Niveaux fonctionnels obsolètes (+ Low)** : Le domaine utilise des niveaux fonctionnels anciens, ce qui empêche l'activation des protections Kerberos modernes (comme les silos d'authentification).
- **Création de comptes ordinateurs par des non-privilegiés (+ Low)** : Comme vu précédemment, des utilisateurs standards peuvent ajouter des machines au domaine. C'est un vecteur classique pour introduire des outils de piratage dans le réseau.
- **Groupe "Protected Users" non utilisé (Info)** : Ce groupe de sécurité moderne, qui durcit radicalement la sécurité des comptes (pas de NTLM, pas de délégation, etc.), n'est pas exploité pour vos comptes sensibles.

## 4. Analyse des Vulnérabilités Critiques (Les "Critiques")



SECURITY INDICATOR

**gMSA not in use**

IOE Found

B

94%

SEVERITY

Medium

WEIGHT

4

Security Frameworks

MITRE ATT&CK

- Credential Access

Description

This indicator checks if there are enabled group Managed Service Account (gMSA) objects in the domain.

Likelihood of Compromise

The group Managed Service Account (gMSA) feature in Windows Server 2016 allows automatic rotation of passwords for service accounts, making them much more difficult for attackers to compromise. The feature should be used whenever possible for service accounts.

References

[Get started with Group Managed Service Accounts](#)

Result

Found 1 domains with no gMSA objects enabled.

| DomainName | Ignored |
|------------|---------|
| lab.local  | False   |

Showing 1 of 1

Remediation Steps

Group Managed Service Accounts should be used to protect service accounts. See description for more information.

# gMSA not in use (Sévérité Moyenne)

Cet indicateur vérifie s'il existe des objets de type "Group Managed Service Account" (gMSA) actifs dans le domaine.

**Explication (Cause) :** L'infrastructure utilise des comptes utilisateurs classiques ou des comptes de service locaux pour le fonctionnement des applications et services réseau. Aucun objet **Group Managed Service Account (gMSA)** n'est détecté dans le domaine lab.local. Ces comptes standards imposent une gestion manuelle des mots de passe, menant souvent à l'utilisation de secrets statiques ou sans expiration.

**Conséquence (Risque) :** L'absence de **gMSA** accroît la vulnérabilité des comptes de service aux compromissions de type **Credential Access** (framework MITRE ATT&CK). Contrairement aux comptes classiques, la fonctionnalité gMSA assure une rotation automatique et complexe des mots de passe gérée par l'Active Directory, rendant le craquage par force brute ou le vol d'identifiants extrêmement difficiles.

1

SECURITY INDICATOR

Unprivileged users can add computer accounts to the domain

IOE Found

96%

SEVERITY

Low

WEIGHT

3

Security Frameworks

MITRE ATT&CK

- Credential Access
- Lateral Movement

ANSSI

- vuln4\_user\_accounts\_machineaccountquota

Description

This indicator checks for an AD configuration that allows unprivileged domain members to add computer accounts to the domain. By default, members of the Authenticated Users group can add up to 10 machine accounts to a domain. If the ms-DS-MachineAccountQuota attribute on the domain naming context head is not set to 0, regular users have this ability. The ability to do this confers certain rights on those created machine accounts that can be abused by a variety of Kerberos-based attacks. Note: This configuration may be enabled but be already mitigated by GPO settings (User Right: "Add workstations to domain" configured with only high-privileged group(s)/account(s)) linked to Domain Controllers OU that are not checked by this indicator.

Likelihood of Compromise

The ability to add computer accounts to a domain without restrictions or monitoring present opportunities for attackers to add their own accounts or take advantage of uncontrolled computers with vulnerabilities, thereby extending their reach and entrenching themselves in the environment.

References

[Unrestricted domain join | ANSSI](#)

Result

Found 1 domains in which regular users can add computer accounts.

| DistinguishedName | MachineAccountQuota | Ignored |
|-------------------|---------------------|---------|
| DC=lab,DC=local   | 10                  | False   |

Showing 1 of 1

Remediation Steps

Set the ms-DS-MachineAccountQuota attribute on the domain NC head to 0 to disable regular users' ability to add computer accounts.

## Unprivileged users can add computer accounts to the domain

Cet indicateur vérifie la configuration de l'Active Directory qui autorise les membres ordinaires du domaine à joindre des machines à l'annuaire.

- **Explication (Cause) :** Par défaut, l'attribut ms-DS-MachineAccountQuota est réglé sur la valeur **10** au niveau de l'annuaire. Cela autorise n'importe quel membre du

groupe "**Utilisateurs authentifiés**" à créer jusqu'à 10 comptes d'ordinateurs dans le domaine sans intervention d'un administrateur.

- **Conséquence (Risque)** : Cette capacité permet l'introduction de machines non contrôlées sur le réseau. Cela facilite les mouvements latéraux au sein de l'infrastructure lab.local et autorise des attaques basées sur le protocole **Kerberos**.

 SECURITY INDICATOR

Built-in domain Administrator account used within the last two weeks

IOE Found 

SEVERITY

Medium

WEIGHT

5

**Security Frameworks**

MITRE ATT&CK

- Credential Access

MITRE D3FEND

- Detect - Credential Compromise Scope Analysis
- Harden - Strong Password Policy

**Description**

The Domain Administrator account should only be used for initial build activities and, when necessary, disaster recovery. This indicator checks to see if the lastLogonTimestamp for the built-in Domain Administrator account has been updated within the last two weeks. If so, it could indicate that the user has been compromised.

**Likelihood of Compromise**

If best practices are followed and domain Admin is not used, this would indicate a compromise. Ensure any logins to the built-in Domain Administrator account are legitimate and accounted for. If not accounted for, a breach is likely and should be investigated.

**Result**

Found 1 domains in which the built-in administrator was used recently.

| DistinguishedName                         | EventTimestamp      | Ignored |
|-------------------------------------------|---------------------|---------|
| CN=Administrator,CN=Users,DC=lab,DC=local | 12/01/2026 12:47:37 | False   |

Showing 1 of 1

**Remediation Steps**

Ensure that the built-in domain Administrator account is not used regularly and has a complex password known only to highly privileged admins.

## Built-in domain Administrator account used within the last two weeks

Cet indicateur vérifie si la valeur de l'attribut lastLogonTimestamp du compte administrateur par défaut a été mise à jour au cours des deux dernières semaines.

- **Explication (Cause)** : L'attribut lastLogonTimestamp du compte "**Administrator**" intégré indique une utilisation pour des tâches de maintenance ou de configuration au cours des 14 derniers jours dans le domaine lab.local.
- **Conséquence (Risque)** : L'utilisation de ce compte générique empêche la traçabilité nominative des actions d'administration. En cas de compromission, l'attaquant dispose immédiatement des privilèges les plus élevés sur toute la forêt, rendant la détection de la brèche difficile et compromettant l'intégrité globale de l'infrastructure.





## SECURITY INDICATOR

### AD objects created within the last 10 days

IOE Found



#### SEVERITY

Info

#### WEIGHT

1

#### Security Frameworks

##### MITRE ATT&CK

- Lateral Movement
- Persistence

##### MITRE D3FEND

- Detect - Domain Account Monitoring

#### Description

This indicator looks for any AD objects that were created within the last 10 days. It is meant to be used for threat hunting, post-breach investigation or compliance validation.

#### Likelihood of Compromise

In some environments, object creation happens consistently; however, recently added accounts should be reviewed to ensure they are legitimate.

#### References

[Audit User Account Management | Microsoft Learn](#)

#### Result

Found 3 objects that were created in the last 10 days.

| DistinguishedName                                                                 | ObjectName                                           | ObjectClass | EventTimestamp      |
|-----------------------------------------------------------------------------------|------------------------------------------------------|-------------|---------------------|
| CN=WIN-11,CN=Computers,DC=lab,DC=local                                            | WIN-11                                               | computer    | 12/01/2026 12:47:40 |
| CN=BCKUPKEY_PREFERRED Secret,CN=System,DC=lab,DC=local                            | BCKUPKEY_PREFERRED Secret                            | secret      | 12/01/2026 12:50:07 |
| CN=BCKUPKEY_d725f7c4-d05f-4cdd-879e-6b4dc6476136 Secret,CN=System,DC=lab,DC=local | BCKUPKEY_d725f7c4-d05f-4cdd-879e-6b4dc6476136 Secret | secret      | 12/01/2026 12:50:07 |

Showing 3 of 3

## AD objects created within the last 10 days

Cet indicateur est utilisé pour la surveillance proactive (**threat hunting**) et la validation de la conformité des changements récents dans l'Active Directory.

- **Explication (Cause)** : L'analyse de la base de données de l'annuaire lab.local liste les nouveaux objets (utilisateurs, conteneurs, politiques) de création récente. Ce nombre est élevé lors de phases de déploiement neuf.
- **Conséquence (Risque)** : Cet indicateur est crucial pour détecter des comptes "dormants" ou illégitimes créés pour maintenir un accès persistant après une intrusion. Une augmentation inexpliquée d'objets peut signaler une compromission en cours.



## SECURITY INDICATOR

### Recent privileged account creation activity

IOE Found

92%

#### SEVERITY

Low

#### WEIGHT

3

#### Security Frameworks

MITRE ATT&CK

- Persistence

MITRE D3FEND

- Detect - Domain Account Monitoring

#### Description

This indicator looks for any users or groups that were created within the last month. Privileged accounts and groups are defined by having their adminCount attribute set to 1.

#### Likelihood of Compromise

In most environments, creation of privileged accounts and groups is tightly controlled and audited. This indicator provides a fast method to create a list of new privileged accounts (where adminCount = 1) for investigation and review.

#### References

[audit-user-account-management of Microsoft](#)

#### Result

Found 2 objects that were created in the last 30 days and are members of a privileged group.

| DistinguishedName                         | SamAccountName | EventTimestamp      | Ignored |
|-------------------------------------------|----------------|---------------------|---------|
| CN=Administrator,CN=Users,DC=lab,DC=local | Administrator  | 08/01/2026 14:50:20 | False   |
| CN=krbtgt,CN=Users,DC=lab,DC=local        | krbtgt         | 08/01/2026 14:50:20 | False   |

Showing 2 of 2

#### Remediation Steps

Review the list and verify that all privileged accounts and groups that were recently created are valid. Ideally, all privileged account creation goes through an approval-based workflow and gets periodic attestation.

Cet indicateur recherche les utilisateurs ou groupes créés au cours du dernier mois dont l'attribut adminCount est défini sur **1**.

- **Explication (Cause)** : De nouveaux comptes disposant de droits d'administration élevés ont été détectés sur le domaine stage.local au cours des 30 derniers jours. Cela correspond généralement à la phase d'installation initiale.
- **Conséquence (Risque)** : En environnement stable, la création de comptes privilégiés doit être rare et auditée. Un attaquant cherche souvent à créer un compte "Super Admin" pour garantir son maintien dans le système ; cet indicateur permet de repérer toute élévation de privilèges suspecte.



## SECURITY INDICATOR Protected Users group not in use

IOE Found

99%

SEVERITY  
Info

WEIGHT  
1

### Security Frameworks

MITRE ATT&CK

- Credential Access

ANSSI

- vuln3\_protected\_users

### Description

This indicator checks if privileged users are in the Protected Users security group.

### Likelihood of Compromise

The Protected Users security group was introduced in Server 2012 R2 Active Directory to minimize credential exposure for privileged accounts. As a defense in depth measure privileged accounts, such as Domain Admins, should be added to the Protected Users security group. Attackers targeting privileged accounts in Active Directory will find a much higher level of friction in certain types of attempts to compromise the accounts due to the protections offered.

### References

[Protected Users Security Group | Microsoft Learn](#)

[Privileged accounts outside of the Protected Users group | ANSSI](#)

### Result

Found 1 privileged users that are not members of the Protected Users group.

| DistinguishedName                         | SamAccountName | Enabled | Ignored |
|-------------------------------------------|----------------|---------|---------|
| CN=Administrator,CN=Users,DC=lab,DC=local | Administrator  | True    | False   |

Showing 1 of 1

### Remediation Steps

Ensure that all privileged users are members of the Protected Users group. If using a pre 2012-R2 schema, then the protected users group does not exist. This is an exposure, but the remediation is to upgrade the schema.

## Protected Users group not in use

Le groupe "**Protected Users**" est un groupe de sécurité spécial introduit par Microsoft (depuis Windows Server 2012 R2) pour protéger les comptes à hauts privilèges.

- **Explication (Cause)** : Aucun compte utilisateur n'est membre du groupe de sécurité spécial "**Protected Users**" dans le domaine lab.local.
- **Conséquence (Risque)** : L'absence d'utilisation de ce groupe prive les comptes sensibles de restrictions automatiques puissantes, telles que l'interdiction de protocoles d'authentification faibles (NTLM, WDigest), l'impossibilité de mettre en cache les identifiants sur les postes, et une réduction de la durée de vie des tickets Kerberos (4h au lieu de 10h).



## SECURITY INDICATOR

### Domains with obsolete functional levels

IOE Found

96%

#### SEVERITY

Low

#### WEIGHT

3

#### Security Frameworks

##### MITRE ATT&CK

- Reconnaissance

##### MITRE D3FEND

- Harden - Software Update

##### ANSSI

- vuln1\_functional\_Level
- vuln3\_functional\_Level
- vuln4\_functional\_Level

#### Description

This indicator looks for AD domains that have a domain functional level set to Windows Server 2012 R2 or lower. These lower functional levels mean that newer security features available in AD cannot be leveraged. If the OS version of your domain controllers supports it, you should update to a newer domain functional level to take full advantage of security advancements in AD.

#### Likelihood of Compromise

While domain functional level is not a weakness in and of itself, an attacker with knowledge of functional levels can adjust their approach to take advantage of lack of security features in AD.

#### References

[Forest and Domain Functional Levels](#)

[Insufficient forest and domains functional levels \(ANSSI\)](#)

#### Result

Found 1 domains with low domain functionality level.

| FunctionalLevel | DomainName | FunctionalLevelInfo | Ignored |
|-----------------|------------|---------------------|---------|
| 4               | lab.local  | 2008 R2             | False   |

Showing 1 of 1

## Domains with obsolete functional levels

Cet indicateur recherche les domaines dont le niveau fonctionnel est réglé sur **Windows Server 2012 R2 ou inférieur**.

- **Explication (Cause)** : Le domaine lab.local dispose d'un niveau fonctionnel **2008 R2**. Samba 4 émule souvent ce niveau par défaut pour assurer la compatibilité.
- **Conséquence (Risque)** : Bien qu'il ne s'agisse pas d'une faille directe, cela constitue une faiblesse structurelle empêchant l'activation de fonctionnalités de sécurité modernes telles que la **Corbeille Active Directory** ou les politiques de silos d'authentification Kerberos.

LDAP signing is not required on Domain Controllers

IOE Found82%

SEVERITY

High

WEIGHT

7

Security Frameworks

MITRE ATT&CK

- Privilege Escalation
- Credential Access

Description

This indicator checks for domain controllers where LDAP signing is not required.

Likelihood of Compromise

Unsigned network traffic is exposed to MITM attacks, where attackers alter packets and forward them to the LDAP server, causing the server to make decisions based on forged requests from the LDAP client.

References

[Domain controller LDAP server signing requirements - Windows 10 | Microsoft Learn](#)  
[Network security LDAP client signing requirements - Windows 10 | Microsoft Learn](#)

Result

Found 1 DCs that do not require LDAP Signing.

| DistinguishedName                                 | HostName           | State                     | Ignored |
|---------------------------------------------------|--------------------|---------------------------|---------|
| CN=SAMBA-AD,OU=Domain Controllers,DC=lab,DC=local | SAMBA-AD.lab.local | Ldap Signing Not Required | False   |

Showing 1 of 1

Remediation Steps

To remediate follow the steps below:  
If the steps are not followed in order, disruption to Active Directory may occur.

1. Configure clients to request LDAP signing. Group policy: **Network security:LDAP client signing requirements**, select **Negotiate signing**.
2. When all clients request signing, configure domain controllers to require LDAP signing. Group policy: **Domain Controller:LDAP server signing requirements**, select **Require signing**.
3. Configure clients to require LDAP signing. Group policy: **Network security:LDAP client signing requirements**, select **Require signing**.
4. For full details on the process please see the reference articles.

## LDAP signing is not required on Domain Controllers

Cet indicateur vérifie si les contrôleurs de domaine exigent que les clients négocient la signature LDAP.

- **Explication (Cause)** : Le serveur n'oblige pas la signature des communications LDAP, souvent pour maintenir la compatibilité avec des clients anciens. Le trafic circule sans garantie d'intégrité.
- **Conséquence (Risque)** : Le trafic non signé est exposé à des attaques de type **Man-in-the-Middle (MitM)**. Un attaquant peut intercepter et modifier les paquets, menant potentiellement à une élévation de privilèges ou au vol d'informations sensibles.

SECURITY INDICATOR

SMB Signing is not required on Domain Controllers

IOE Found 73%

SEVERITY

Critical

WEIGHT

8

Security Frameworks

MITRE ATT&CK

- Privilege Escalation
- Credential Access

Description

This indicator looks for domain controllers where SMB signing is not required.

Likelihood of Compromise

Unsigned network traffic is susceptible to attacks abusing the NTLM challenge-response protocol. A common example of such attacks is SMB Relay, where an attacker is positioned between the client and the server in order to capture data packets transmitted between the two, thus gaining unauthorized access to the server or other servers on the network.

References

[Configure SMB Signing with Confidence](#)

Result

Found 1 DCs that do not require SMB Signing.

| DistinguishedName                                 | HostName           | State                       | Ignored |
|---------------------------------------------------|--------------------|-----------------------------|---------|
| CN=SAMBA-AD,OU=Domain Controllers,DC=lab,DC=local | SAMBA-AD.lab.local | SMB Signing is not required | False   |

Showing 1 of 1

Remediation Steps

The following Group Policies need to be enabled in order to enforce SMB Signing on DCs:

- Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > Security Options > Microsoft network server: Digitally sign communications (always): This policy controls whether the server providing SMB required signing. It determines if SMB signing will have to be negotiated prior to further communication.
- Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > Security Options > Microsoft network server: Digitally sign communications (if client agrees): This policy determines if SMB server will negotiate SMB signing with clients that request it.

## SMB Signing is not required (La signature)

- **Explication (Cause)** : Le serveur n'oblige pas les clients à signer numériquement les messages, même en utilisant les versions SMBv2 ou v3.
- **Conséquence (Risque)** : Cette faille d'usurpation permet à un attaquant de se placer en interception (MitM) entre l'administrateur et le serveur pour envoyer des ordres illégitimes au serveur en se faisant passer pour l'administrateur.

SECURITY INDICATOR

SMBv1 is enabled on Domain Controllers

IOE Found 73%

SEVERITY

Critical

WEIGHT

8

Security Frameworks

MITRE ATT&CK

- Privilege Escalation
- Credential Access

Description

This indicator looks for domain controllers where SMBv1 protocol is enabled.

Likelihood of Compromise

SMBv1 is an old protocol, considered unsafe and susceptible to all kinds of attacks. It was publicly deprecated by Microsoft in 2014.

References

[Configure SMB Signing with Confidence](#)

Result

Found 1 DCs with SMBv1 Enabled.

| DistinguishedName                                 | HostName           | State            | Ignored |
|---------------------------------------------------|--------------------|------------------|---------|
| CN=SAMBA-AD,OU=Domain Controllers,DC=lab,DC=local | SAMBA-AD.lab.local | SMBv1 is enabled | False   |

Showing 1 of 1

Remediation Steps

Microsoft recommends to disable SMBv1 whenever possible on both client and server side. Do note, before disabling SMBv1 and to avoid additional errors, make sure best practices are followed regarding the usage of deprecated OS (Windows 2000, 2003, XP, CE), network printers using SMBv1 scan2shares functionalities, or software accessing Windows share with a custom implementation relying on SMBv1.

## SMBv1 is enabled (Le protocole)

- **Explication (Cause)** : Le serveur accepte encore la version 1 du protocole SMB, désormais obsolète.
- **Conséquence (Risque)** : Ce protocole contient des vulnérabilités critiques permettant l'exécution de code à distance et la prise de contrôle totale du serveur (ex: exploitation par WannaCry).

 SECURITY INDICATOR  
**Write access to RBCD on DC**

IOE Found  88%

SEVERITY  
High

WEIGHT  
6

**Security Frameworks**  
MITRE ATT&CK

- Credential Access

**Description**  
This indicator looks for Write access on RBCD for Domain Controllers to users who are not in Domain Admins, Enterprise Admins and Built-in Admins groups.

**Likelihood of Compromise**  
This setting enables configuring RBCD on Domain Controllers. An attacker that is able to gain Write access to RBCD for a resource can cause that resource to impersonate any user (except where delegation is explicitly disallowed). Write on RBCD is always a high privilege, but when it is on a DC, the impact is substantial as an attacker can delegate to a controlled resource as a privileged user and abuse the DC services.

**Result**  
Found 1 DCs on which the listed principals can write to their msds-AllowedToActOnBehalfOfOtherIdentity attribute.

| Access                                            | DistinguishedName                                 | Ignored |
|---------------------------------------------------|---------------------------------------------------|---------|
| S-1-5-32-548 Allow: GenericAll on: All Properties | CN=SAMBA-AD,OU=Domain Controllers,DC=lab,DC=local | False   |

Showing 1 of 1

**Remediation Steps**  
For each DC listed, ensure that the principals who can set resource-based constrained delegation are valid.

## Write access to RBCD on DC (Sévérité Haute)

Cet indicateur vérifie s'il existe des utilisateurs (en dehors des groupes d'administration restreints) possédant des droits d'écriture sur l'attribut de délégation Kerberos basée sur les ressources (RBCD) des contrôleurs de domaine.

- **Explication (Cause)** : Un principal de sécurité non-administrateur dispose de la permission GenericAll sur l'objet contrôleur de domaine **SAMBA-AD**. Cela autorise la modification de l'attribut msds-AllowedToActOnBehalfOfOtherIdentity du serveur critique.
- **Conséquence (Risque)** : Ce réglage permet une compromission totale via une escalade de privilèges par usurpation d'identité. Un attaquant peut configurer le DC pour autoriser une machine contrôlée à usurper l'identité de n'importe quel utilisateur, facilitant la prise de contrôle du DC et l'accès aux identifiants (Credential Access).



#### SECURITY INDICATOR

#### Write access to RBCD on krbtgt account

IOE Found

64%

#### SEVERITY

High

#### WEIGHT

7

#### Security Frameworks

MITRE ATT&CK

- Credential Access

#### Description

This indicator looks for Write access on RBCD for the krbtgt account to users who are not in Domain Admins, Enterprise Admins and Built-in Admins groups.

#### Likelihood of Compromise

This setting enables configuring RBCD on the krbtgt account. An attacker that is able to gain Write access to RBCD for a resource can cause that resource to impersonate any user (except where delegation is explicitly disallowed). Write on RBCD is always a high privilege, but when it is on the krbtgt account, the impact is substantial because it allows the attacker to create TGS for krbtgt for any user, which can then be used as a TGT.

#### Result

Found 2 principals that can write to msds-AllowedToActOnBehalfOfOtherIdentity on krbtgt.

| Identity         | DistinguishedName                  | Access                                                                          | Ignored |
|------------------|------------------------------------|---------------------------------------------------------------------------------|---------|
| AUTORITE NT\SELF | CN=krbtgt,CN=Users,DC=lab,DC=local | Allow: ReadProperty, WriteProperty on: msds-AllowedToActOnBehalfOfOtherIdentity | False   |
| S-1-5-32-548     | CN=krbtgt,CN=Users,DC=lab,DC=local | Allow: GenericAll on: All Properties                                            | False   |

Showing 2 of 2

#### Remediation Steps

Review the list and ensure that there are no unnecessary principals who can set resource-based constrained delegation on krbtgt.

## Write access to RBCD on krbtgt account

Cet indicateur recherche les utilisateurs (en dehors des groupes d'administration restreints) qui possèdent des droits d'écriture sur l'attribut msds-AllowedToActOnBehalfOfOtherIdentity du compte **krbtgt**. Le compte **krbtgt** est le compte le plus sensible de l'Active Directory, car il sert à signer tous les tickets d'authentification Kerberos du domaine.

- **Explication (Cause)** : Des permissions de type GenericAll sont accordées à un SID non-administrateur sur l'objet **CN=krbtgt,CN=Users,DC=lab,DC=local**.
- **Conséquence (Risque)** : Il s'agit d'une vulnérabilité majeure permettant une compromission persistante de la forêt. Un attaquant peut configurer une délégation RBCD pour forcer le compte **krbtgt** à usurper l'identité de n'importe quel utilisateur, permettant la génération de tickets frauduleux (Golden Ticket) et l'accès permanent aux droits d'administrateur du domaine.